

This chapter covers the following topics related to Objective 4.1 (Explain the importance of basic network security concepts) of the CompTIA Network+ N10-009 certification exam:

- Logical security
  - Encryption
    - Data in transit
    - Data at rest
  - Certificates
    - Public key infrastructure (PKI)
    - Self-signed
  - Identity and access management (IAM)
    - Authentication
      - Multifactor authentication (MFA)
      - Single sign-on (SSO)
      - Remote Authentication Dial-in User Service (RADIUS)
      - LDAP
      - Security Assertion Markup Language (SAML)
      - Terminal Access Controller Access Control System Plus (TACACS+)
      - Time-based authentication
    - Authorization
      - Least privilege
      - Role-based access control
  - Geofencing
- Physical security
  - Camera
  - Locks
- Deception technologies
  - Honeypot
  - Honeynet
- Common security terminology
  - Risk
  - Vulnerability
  - Exploit
  - Threat
  - Confidentiality, Integrity, and Availability (CIA) triad
- Audits and regulatory compliance
  - Data locality
  - Payment Card Industry Data Security Standards (PCI DSS)
  - General Data Protection Regulation (GDPR)
- Network segmentation enforcement
  - Internet of Things (IoT) and Industrial Internet of Things (IIoT)
  - Supervisory control and data acquisition (SCADA), industrial control system (ICS), operational technology (OT)
  - Guest
  - Bring your own device (BYOD)

CHAPTER 18

Network Security Concepts

Today's networks are increasingly dependent on connectivity with other networks. However, connecting an organization's trusted network to untrusted networks, such as the Internet, introduces security risks. Security risks exist even internally within an organization.

To protect your organization's data from malicious users, you need to understand the types of threats against which you might have to defend. Then you need to know your options for defending the network. A key security concept to understand is that you need multiple layers of security (*defense in depth*) for your network, not just a single solution, such as a firewall. You might, for example, combine user training, security policies, remote access security protocols, firewalls, VPNs, and intrusion prevention systems to provide overlapping layers of network protection.

This chapter begins by introducing the fundamentals of security, including a discussion of both logical and physical security mechanisms. This chapter also presents the most common authentication methods used in networks today, network segmentation methods, and regulatory compliance.

Foundation Topics

Core Security Concepts

This section examines several very important core security concepts that are critical for you to understand in the current cybersecurity landscape—starting with ***confidentiality, integrity, and availability (CIA)***. This is often termed the *CIA Triad*.

Key Topic

Confidentiality, Integrity, and Availability (CIA)

For most of today's corporate networks, the demands of e-commerce and customer contact require connectivity between internal corporate networks and the outside world. Today's corporate networks tend to be large and interconnected with other networks, and they typically run both standards-based and proprietary protocols. Of course, another massive trend has been cloud technologies, where once again, networks connecting to other networks is critical for proper functionality of systems.

In addition, the devices and applications connecting to and using corporate networks are continually increasing in complexity. It would be unusual for a corporate network not to need network security.

CIA refers to the three primary goals of network security:

- Confidentiality
- Integrity
- Availability

The following sections explain these goals in more detail.

Confidentiality

Data confidentiality involves keeping data private by physically or logically restricting access to sensitive data or encrypting traffic traversing a network. While much of this chapter deals with ***logical security*** mechanisms, we will also be examining ***physical security*** as well.

A network that provides confidentiality would, for example, do the following:

- Use network security mechanisms, such as firewalls and access control lists (ACLs), to prevent unauthorized access to network resources.
- Require appropriate credentials (such as usernames and passwords) to access specific network resources.

- Encrypt traffic such that any traffic captured off the network by an attacker could not be deciphered by the attacker.

Confidentiality can be provided by using ***encryption***. Encryption allows a packet to be encoded in such a way that it can be decoded by an intended party. However, a malicious user who intercepted an encrypted packet in transit would not be able to decrypt the packet. The way most modern encryption algorithms prevent decryption by a third party is through the use of a *key*. Because the encryption or decryption algorithm uses a key in its mathematical calculation, a third party who does not possess the key cannot interpret intercepted data that is encrypted.

When you are planning for encryption in your network, it is important to remember the three states of data introduced in Chapter 17, "Network Access and Management Methods." The states of data are ***data in transit***, ***data at rest***, and ***data in use***. An example of data in transit is when you are downloading information from the cloud. Data at rest is when you are storing the data, and data in use is when you are actually working with the data. While encryption is not typically used with data in use, we include this state of data here for completion's sake and so we do not forget to consider it when we are planning our network security.

Encryption has two basic forms: *symmetric encryption* and *asymmetric encryption*. As you will learn next, symmetric key algorithms are faster and are often used for bulk encryption of data. Asymmetric key algorithms are slower and are often used for initial security transactions such as authentication.

Symmetric Encryption

Key Topic

Symmetric encryption is faster than asymmetric encryption. The word symmetric in symmetric encryption implies that the same key is used by both the sender and the receiver to encrypt or decrypt a packet. Examples of symmetric encryption algorithms include the following:

- **DES:** Data Encryption Standard (DES) is an older encryption algorithm (developed in the mid-1970s) that uses a 56-bit key. It is considered weak by today's standards and has been deprecated.
- **3DES:** Triple DES (3DES), developed in the late 1990s, uses three 56-bit DES keys (for a total of 168 bits) and was originally considered a strong encryption algorithm. However, the security of 3DES varies based on the way it is implemented. Specifically, 3DES has three keying options: All three keys may be different (keying option 1), two of the three keys may be the same (keying option 2), or all three keys may be the same (keying option 3) to maintain backward compatibility with DES. Because of the high computational

overhead of 3DES, many companies have moved directly to the much faster AES instead of using 3DES.

- **AES:** Advanced Encryption Standard (AES), released in 2001, is the preferred symmetric encryption algorithm. AES, which is a variant of the Rijndael family of symmetric ciphers, is available in 128-bit key, 192-bit key, and 256-bit key versions. This technology is being used more and more for many different applications, including wireless, mobile, VPNs, and web security implementations. It is popular because of its overall strength and its ability to provide various levels of security based on key length. For lower-security environments, you can use 128-bit key AES; a 256-bit key implementation is considered almost unbreakable.

Figure 18-1 provides an example of symmetric encryption, where both parties have a shared key to be used during a session (called a *session key*).

NOTE Another widely deployed encryption algorithm is Pretty Good Privacy (PGP), which is often used to encrypt email traffic. PGP uses both symmetric and asymmetric algorithms. A free variant of PGP is GNU Privacy Guard (GPG).

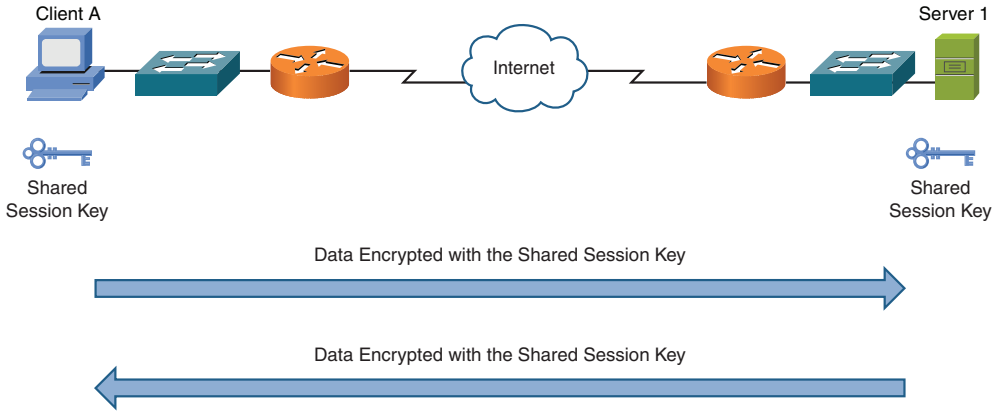


Figure 18-1 Symmetric Encryption Example

Key Topic

Asymmetric Encryption

Asymmetric encryption is slow compared to symmetric encryption but provides better security. As its name suggests, asymmetric encryption uses asymmetric (different) keys for the sender and the receiver of a packet. Because of its speed, asymmetric encryption is not typically used to encrypt large quantities of real-time data. Rather,

asymmetric encryption might be used to encrypt a small chunk of data used, for example, to authenticate the other party in a conversation or to exchange a shared key to be used during a session (after which the parties in the conversation could start using symmetric encryption). One of the most popular asymmetric encryption algorithms in use today is RSA; its name comes from the last initials of its inventors: Ronald L. Rivest, Adi Shamir, and Leonard M. Adleman.

RSA is commonly used as part of a ***public key infrastructure (PKI)*** system. Specifically, PKI uses digital ***certificates*** and a certificate authority (CA) for authentication and encryption services.

For example, in the example shown in Figure 18-2, when client A wants to communicate securely with server 1, the following steps occur:

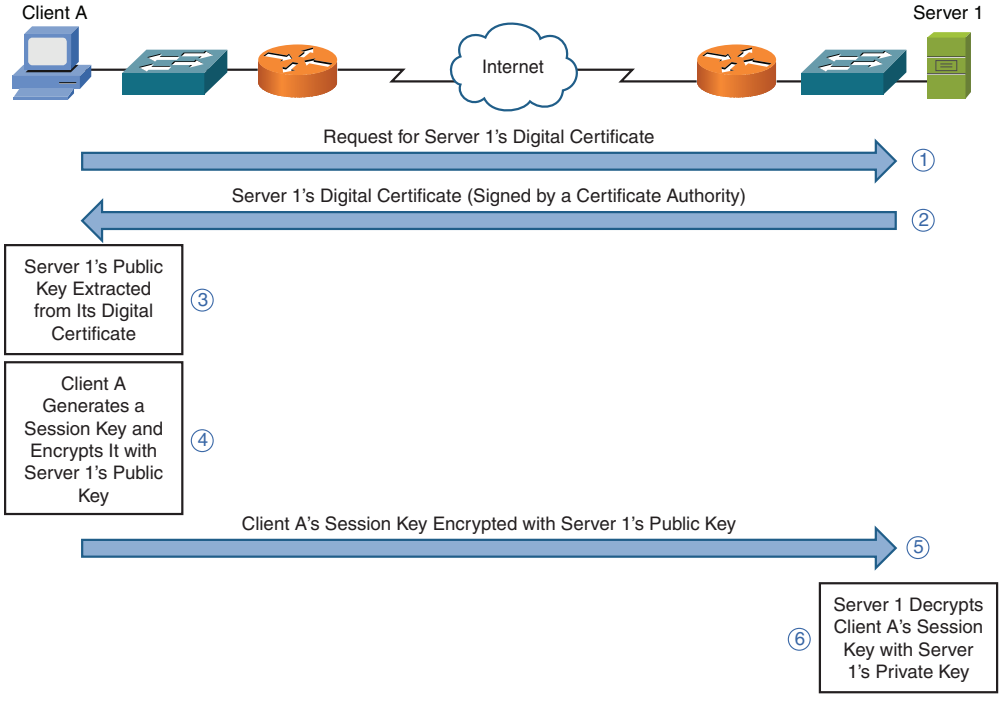


Figure 18-2 Asymmetric Encryption Example

Step 1. Client A requests server 1's digital certificate.

Step 2. Server 1 sends its digital certificate, and client A knows the received certificate is really from server 1 because the certificate has been authenticated (*signed*) by a trusted third party, called a *certificate authority*.

Step 3. Client A extracts server 1's public key from server 1's digital certificate. Data encrypted using server 1's public key can only be decrypted with server 1's private key, which only server 1 has.

Step 4. Client A generates a random string of data called a *session key*.

Step 5. The session key is encrypted using server 1's public key and sent to server 1.

Step 6. Server 1 decrypts the session key by using its private key.

At this point, both client A and server 1 know the session key, which can be used to symmetrically encrypt traffic during the session.

NOTE While PKI is amazing and relied upon for almost all Internet security today, there is also the option to use digital certificates that are ***self-signed***. This permits the technology to protect internal corporate communications without involving the trusted third party.

Key Topic

Integrity

Ensuring data *integrity* involves making sure data has not been modified in transit. Also, a data integrity solution might perform origin authentication to verify that traffic is originating from the source that should send the traffic.

Examples of integrity violations include the following:

- Modifying the appearance of a corporate website
- Intercepting and altering an e-commerce transaction
- Modifying financial records that are stored electronically

Hashing is one approach to providing integrity to data transmissions crossing a network. Specifically, hashing takes a string of data (such as a password) and runs it through an algorithm. The result of the algorithm is called a *hash* or a *hash digest*. If the sender of that data runs a hashing algorithm on the data and sends the hash digest along with the data, when the recipient receives the data, she can also run the data through the same hashing algorithm. If the recipient calculates the same hash digest, she might conclude that the data has not been modified in transit (that is, she has confirmed the integrity of the data). Note that a hashing algorithm produces hash digests of the same length, regardless of the size of the data being hashed.

Two hashing algorithms are commonly used:

- **Message Digest 5 (MD5):** Creates 128-bit hash digests

- **Secure Hash Algorithm 1 (SHA-1):** Creates 160-bit hash digests
- **Secure Hash Algorithm 2 (SHA-2):** Creates 224-, 256-, 384-, and 512-bit hash digests

Hashing by itself, however, does not guarantee data integrity because an attacker could intercept a string of data, manipulate it, and recalculate the hash value based on the manipulated data. The victim would then determine that the hash is valid based on the data. To overcome this limitation of pure hashing, Hashed Message Authentication Code (HMAC) uses an additional secret key in the calculation of a hash value. Therefore, an attacker would not be able to create a valid hash value because he would not know the secret key. Other variants of hashing algorithms, such as SHA-256, involve longer digests. In cryptography, a bigger digest implies better security.

NOTE Challenge-Response Authentication Mechanism Message Digest 5 (CRAM-MD5) was a common variant of HMAC frequently used in email systems. Today, even this enhancement has been deprecated in favor of more secure technologies such as SSL and TLS.

Availability

The availability of data is a measure of the data's accessibility. For example, as we covered back in Chapter 15, "Disaster Recovery," if a server were down only 5 minutes per year, the server would have an availability of 99.999% (that is, *five nines availability*).

Here are a couple of examples of how an attacker could attempt to compromise the availability of a network:

- Send improperly formatted data to a networked device, resulting in an unhandled exception error.
- Flood a network system with an excessive amount of traffic or requests, which would consume a system's processing resources and prevent the system from responding to many legitimate requests. This type of attack is commonly referred to as a denial-of-service (DoS) attack.

Threats, Vulnerabilities, Risks, and Exploits

To effectively guard a network against attacks, you should be able to identify a number of security concepts within your own environment, as described in this section.

Threats

You should work with your team to carefully identify the realistic security ***threats*** that your enterprise could face. This might mean dealing with hypotheticals, but it is nonetheless a very important exercise. While the focus is often on external threats to an organization, you cannot forget that internal threats exist. In fact, a network often faces more internal threats than external ones.

Vulnerabilities

One of the reasons there are so many potential threats against organizations today is the fact that ***vulnerabilities*** are constantly discovered in networks and network components. New code installed on a network device (such as a router) might cause a vulnerability. For example, this code could introduce a new feature that creates a backdoor into the device for unauthorized persons.

Because vulnerabilities are a major issue for IT staff, a number of tools have been developed to deal with them. The *Common Vulnerabilities and Exposures (CVE)* system is free to use and can be incredibly helpful. This online resource provides excellent search tools and can leverage a large database of publicly known information security vulnerabilities and exposures. CVE, which was officially launched in September 1999, is sponsored by US-CERT within the U.S. Department of Homeland Security (DHS). The MITRE Corporation maintains a CVE dictionary at https://cve.mitre.org.

NOTE The two catalogs of known vulnerabilities you should be familiar with are CVE and CVSS. CVE is a list of publicly known vulnerabilities containing an ID number, description, and reference for each vulnerability. The Common Vulnerability Scoring System (CVSS) provides a score from 0 to 10 that indicates the severity of a vulnerability, with a score of 10 being the most severe. The CVSS is maintained by the Forum of Incident Response and Security Teams (FIRST), at https://www.first.org/cvss/. Also of great value is the Open Web Application Security Project (OWASP), which is a foundation that works to improve software security. Each year, OWASP publishes the OWASP Top 10 for web application security exploits. For more information, visit https://owasp.org.

NOTE *Zero-day attacks* are cybersecurity attacks that use techniques or vulnerabilities that have not already been discovered by cybersecurity specialists or anti-malware companies. While it might sound hopeless, remember that today's sophisticated security appliances can typically prevent or mitigate damage from zero-day attacks by using machine learning (ML) to stop activities in a network that are outside the normal baseline activities.

Risks

Risks refer to the potential threats and vulnerabilities that could compromise the confidentiality, integrity, and availability of your network resources, data, and services. These risks can arise from various sources, including cyberattacks like malware, hacking, and phishing, as well as insider threats, physical breaches, and system malfunctions. Understanding and managing these risks is crucial for safeguarding sensitive information, maintaining operational continuity, and protecting an organization from financial loss, legal repercussions, and reputational damage.

Exploits

As mentioned a bit earlier, when we discuss threats, we are typically talking about hypotheticals—events that might possibly occur in a network. When we discuss ***exploits***, however, we are talking about facts. An exploit consists of a (hopefully detailed) description of what exactly occurred with a security breach. An exploit often describes the most likely attacker, the technology used, and any vulnerabilities or misconfigurations that made the attack possible.



Least Privilege

An important security best practice that you should implement everywhere possible in your network is ***least privilege***. You and every other person who interacts with the network should always be using a user account that has the least number of privileges required to do a job. It is important to carefully audit the required permissions to complete tasks and then create accounts (or groups) that have just those permissions. Then, if a computer criminal manages to begin operating on the network using your account, the criminal will only be able to accomplish minimal tasks.

NOTE What privileges you can carry out on the network using your user account (and often group membership) are referred to as your ***authorization***.

Implementing least privilege might sound easy, but human nature often opposes this commonsense measure. For example, an administrator might prefer to use an administrator or root account for all administrative tasks because switching between accounts can be tedious.

It can also be very easy to violate this best practice without even knowing it. This often happens in public cloud environments. An administrator may start a free-tier Amazon Web Services (AWS) account using his email address. He may have not studied much about AWS and might not realize that there is a service called AWS Identity and Access Management (IAM) designed for the creation of accounts and

permissions in AWS. The administrator may continue to use that administrative account email address for day-to-day operations in AWS, even though AWS makes it clear that using such a high-level account is not safe. The only time you should use that high-level admin account is when you are performing some specific change that requires it, such as changing the credit card on the account or other billing configurations.

Role-Based Access Control

Most network device designers strive to implement ***role-based access control (RBAC)*** for administrators who must manage devices. In addition, more and more network access models for users are emphasizing RBAC for network access.

The idea with RBAC is to create permissions around roles that you can then assign to users. For example, you might use RBAC for guest access; to do so, you would create a guest role and assign that role to visitors to your organization when you want to give them limited privileges. Perhaps you just want such visitors to be able to access your public Internet connection for limited Internet access. You might also use RBAC to create network administrator accounts for users who need to have the ability to access the network and also reconfigure it.

NOTE A scalable method for assigning roles (permissions) to user accounts is to include those user accounts in roles (also called groups) that have the appropriate permissions assigned. The users inherit the permissions thanks to their group membership. On some network devices, RBAC is more limited, and you can assign permissions only to the user accounts themselves.

Defense in Depth

Cisco Systems is one of the networking giants that helped to popularize the great idea of *defense in depth* for network security. Defense in depth involves striving to secure each layer of a solution. For example, you might use strong security on containers and virtual machines that provide software as a service (SaaS) for your organization. You can then use strong security controls for the host systems that provide these virtual servers. You can also have strong security controls in place on the network switch that connects to these hosts. This process continues, building layer after layer of security into the network and the systems that connect to it.

As with the zero trust security approach introduced in Chapter 8, "Evolving Use Cases," there is no single technique that makes defense in depth what it is. This section describes just some of the security approaches you might employ when you are using a defense-in-depth approach.

Screened Subnet

A *screened subnet*—previously called a *demilitarized zone (DMZ)*—often contains servers that should be accessible from the public Internet. With a screened subnet, for example, you could allow users on the Internet to initiate an email or web session coming into your organization's email or web server; however, you could block other protocols for those users.

Separation of Duties

A popular security best practice is to implement a *separation of duties* policy in the network. This policy ensures that user accounts in the network do not have too much power. You can also ensure that your IT staff are mapped to these various duties and even rotated through them. This helps to ensure that internal attacks against your network do not occur. It is important to include separation of duties when planning for security policy compliance. Without this separation, all areas of control and compliance could end up in the hands of a single individual.

Network Access Control

Network access control (NAC) involves using a set of protocols to ensure that users are identified immediately when they try to access the network. A NAC system might integrate automatic remediation processes to fix the issues with host systems so that they are brought in compliance with corporate security policies.

A common approach to building a NAC system is to incorporate 802.1X in the network. 802.1X is covered later in this chapter.

Honeypot

A ***honeypot*** acts as a deception technology. Specifically, a system designated as a honeypot appears to be an attractive attack target. One school of thought on the use of honeypots is to place one or more honeypot systems in a network to entice attackers into thinking a system is real. The attackers then use their resources to attack the honeypot, and in doing so, they leave the real servers alone.

A honeypot can also be used to see what attackers are attempting to do on the system. A honeypot could, for example, be a UNIX- or Linux-based system configured with a weak password. After an attacker logs in, surveillance software could log what the attacker does on the system. This knowledge could then be used to protect real servers in the network.

NOTE For larger networks, a network administrator might deploy multiple honeypots, forming a ***honeynet***.

Network Segmentation Enforcement

Logical segmentation of networks helps to enforce strong security designs. For example, VLANs can be used to constrain broadcasts and permit the definition of VLAN access control lists (ACLs) and router ACLs for controlling communication between VLANs.

Network segmentation enforcement can also help to minimize the effects of security attacks by limiting them to the local subnet. At Layer 3, you can segment by using virtual routing and forwarding (VRF) tables for network devices. These tables, which are like virtual routers running within the main router, can be separate and distinct from the main routing table. The main routing table is termed the *global routing table*.

Of course, network segmentation enforcement can also be based around function. For example, a guest network should most certainly be segmented from non-guest network functions and resources. What follows are some important examples of segmentation based on function.

IoT and IIoT

The ***Internet of Things (IoT)*** refers to the network of everyday objects that are connected to the Internet, allowing them to send and receive data. These objects can include anything from household appliances like refrigerators and thermostats to wearable devices like fitness trackers and smartwatches. By connecting to the Internet, these devices can be controlled remotely, share information with each other, and provide useful data to users, making daily tasks more convenient and efficient. For example, a smart thermostat can learn your temperature preferences and adjust itself automatically, saving energy and improving comfort. Robust security mechanisms should be in place for the IoT infrastructure and it should be properly segmented.

The ***Industrial Internet of Things (IIoT)*** is a network of industrial devices connected to the Internet, allowing them to collect, share, and analyze data. These devices can include machinery, sensors, and equipment used in manufacturing, energy, and other industrial sectors. By being connected, these devices can improve efficiency, reduce downtime, and enhance safety. For example, sensors on a factory machine can detect potential issues before they cause a breakdown, allowing for timely maintenance and avoiding costly interruptions. Overall, IIoT helps industries run more smoothly and effectively by using real-time data and smart technologies.

Like any other network segment, IIoT should be secured as best as possible, and should be properly segmented as much as possible.

SCADA, ICS, and OT

Supervisory control and data acquisition (SCADA) is a system used to monitor and control industrial processes. It involves computers and software that gather real-time data from equipment like sensors and machines in various industries, such as manufacturing, energy, and water treatment. Operators use SCADA systems to see what's happening in their industrial processes, make adjustments, and ensure everything runs smoothly and safely. For instance, in a water treatment plant, SCADA can monitor water levels and chemical usage, allowing operators to maintain the right balance and ensure clean water.

An ***industrial control system (ICS)*** is a group of technologies used to control and automate industrial processes. These systems include devices like sensors, controllers, and software that work together to manage operations in industries such as manufacturing, power plants, and chemical processing. ICS helps ensure that machinery and processes run smoothly, efficiently, and safely. For example, in a power plant, ICS can regulate the flow of electricity, monitor equipment performance, and alert operators to any issues. By automating many tasks and providing real-time data, ICS improves productivity and reduces the risk of errors and accidents.

Operational technology (OT) systems refer to the hardware and software used to detect or cause changes through direct monitoring and control of physical devices, processes, and events within an organization. These systems are critical in industries like manufacturing, energy, and transportation, where they help manage machinery, infrastructure, and facility operations. OT systems include things like programmable logic controllers (PLCs), distributed control systems (DCS), and human-machine interfaces (HMIs).

Guest Networks

Some networks offer ***guest networks*** for, you guessed it, guests. Some of these guest networks even feature open authentication methods that make access simple for users. Properly segmenting guest networks from other, more critical segments is important.

BYOD

Another optional aspect to the modern network is the concept that some organizations permit ***bring your own device (BYOD)***. BYOD is a policy that allows

employees to use their personal devices, such as smartphones, tablets, and laptops, for work purposes. Instead of using company-provided equipment, employees can access company networks, applications, and data on their own devices. This approach can increase convenience and flexibility for employees, as they can work from anywhere and use devices they are already comfortable with. However, it also requires a company to implement strong security measures to protect sensitive information and ensure that personal devices do not pose a risk to the organization's network.

NOTE Some organizations opt for choose your own device (CYOD) instead of BYOD. In the CYOD policy, the employees needing mobile access to corporate resources get to choose their mobile device from a list of approved (and often preconfigured) mobile devices. This gives the organization more control and typically stronger security over the mobile devices. Often, organizations use mobile device management (MDM) software to ensure strict policies governing and managing the approved devices.

Authentication Methods

Authentication is the process of verifying the identity of a user, system, or entity to ensure that it is who or what it claims to be. Because authentication is such an important part of network security, it is little surprise that, today, there are many different approaches you can use. This section describes several authentication methods that all might be found as part of an organization's ***identity and access management (IAM)*** strategy.

Multifactor

Authentication that requires multiple factors is called ***multifactor authentication (MFA)***. The following are some options for components of multifactor authentication:

- Something you know (such as a passcode or pin)
- Something you have (such as a smart card or badge)
- Something you are (such as a fingerprint or retinal scan)
- Something you do (such as a swipe pattern or puzzle completion)
- Somewhere you are (such as a geolocation or IP address)

To ensure that you understand the simplicity and beauty of multifactor authentication, consider this simple example: John goes to the store and puts his bank card into an ATM and enters his PIN. What examples of multifactor authentication has he exhibited?

This automated teller machine (ATM) provides a common example of a multifactor authentication system, requiring both of the following:

- A "something you have" physical key (your ATM card)
- A "something you know" personal identification number (PIN)

Today, smartphones are often used in multifactor authentication. A smartphone is something you possess, and a network can take advantage of this by sending a one-time password (OTP) to your smartphone to make sure you are who you claim to be.

TACACS+

Terminal Access Controller Access Control System Plus (TACACS+) is a Cisco-proprietary TCP-based protocol. TACACS+ has three separate and distinct sessions or functions for authentication, authorization, and accounting (AAA). It is similar to Remote Authentication Dial-In User Service (RADIUS) but uses TCP instead of UDP as a transport method; it uses port 49 as the default port. TACACS+ takes a client/server model approach.

Single Sign-On

Single sign-on (SSO) allows a user to authenticate only once to gain access to multiple systems or applications, without requiring the user to independently authenticate with each system or application.

RADIUS

Remote Authentication Dial-In User Service (RADIUS) is a UDP-based protocol used to communicate with a AAA server. Unlike TACACS+, RADIUS does not encrypt an entire authentication packet; it encrypts only the password. However, RADIUS does offer more robust accounting features than TACACS+. Also, RADIUS is a standards-based protocol, whereas TACACS+ is a Cisco-proprietary protocol. RADIUS uses UDP port 1812 for authentication and authorization and UDP port 1813 for accounting.

LDAP

Lightweight Directory Access Protocol (LDAP) permits a set of standards for the storage and access of user account information. Many proprietary user stores support LDAP for ease of access, including Microsoft's Active Directory. By default, LDAP traffic is unsecured (over port 389). LDAP over TLS/SSL (LDAPS) is a secure form of LDAP with secured communications using port 636.

Kerberos

Kerberos is a client/server authentication protocol that supports mutual authentication between a client and a server. With Kerberos, a trusted third party (a key distribution center [KDC]) hands out tickets that are used instead of username and password combinations.

Here is a look at this process:

Step 1. The client contacts a CA.

Step 2. The CA creates a time-stamped session key with a limited duration (by default, eight hours) by using the client's key and a randomly generated key that includes the identification of the target service.

Step 3. The CA sends this information back to the client in the form of a ticket-granting ticket (TGT).

Step 4. The client submits the TGT to a ticket-granting server (TGS).

Step 5. The TGS generates a time-stamped key encrypted with the service's key and returns both keys to the client.

Step 6. The client uses its key to decrypt its ticket, contacts the server, and offers the encrypted ticket to the TGS.

Step 7. The TGS uses its key to decrypt the ticket and verify that the time stamps match and the ticket remains valid.

Step 8. The service contacts the KDC and receives a time-stamped session-keyed ticket that it returns to the client.

Step 9. The client decrypts the keyed ticket by using its key. When the client and the server agree that they are the proper accounts and that the keys are within their valid lifetimes, communication is initiated.

SAML

Security Assertion Markup Language (SAML) is a standard for securely sharing information about user identities and authentication between different systems. It allows a user to log in once and access multiple, separate applications without needing to log in again for each one. SAML works by passing information (called assertions) about the user from an identity provider (like a company's login system) to a service provider (like a web application). This makes it easier and more secure for users to access different services with a single set of login credentials.

Time-based Authentication

Time-based authentication is a security method that uses a temporary, time-sensitive code for verifying a user's identity. This code is typically generated by an app or sent via SMS and changes every 30 to 60 seconds. When a user logs in, they must enter this code along with their regular password. Because the code is constantly changing, it adds an extra layer of security, making it much harder for unauthorized users to gain access even if they know the password. This method is commonly used in two-factor authentication (2FA) to enhance online account security.

Local Authentication

Local authentication refers to a network device authenticating the user with a database of user account information stored on the device itself. This is often an important fallback authentication method used when another external method fails.

Risk Management and SIEM

It is time to tackle a new subject, risk management, and revisit one that we first saw in Chapter 14, "Network Monitoring"—security information and event management (SIEM). Every organization should consider risk management, and many would argue that every organization should also consider SIEM. Both of these areas can help an organization save money, save time, and, ultimately, be more secure.

Risk Management

It is important for an organization to take a formal approach to *risk management* in order to secure the organization and also help ensure that the organization is spending its time and resources on the best possible security solutions for the situation.

Risk management involves carefully identifying, evaluating, and prioritizing risks. It typically also involves the coordinated application of resources to minimize, monitor, and control the probability or impact of cybersecurity-related events.

Security Risk Assessments

Cybersecurity concerns continue to increase in number and importance. Fortunately, there are many assessments you can conduct to help improve the overall security of your network infrastructure. This section details some of the ones you should be familiar with.

Threat Assessment

Often, as part of risk management, you need to engage in *threat assessment*. This process involves evaluating the credibility and seriousness of potential threats and analyzing the probability that particular threats will become a reality.

Vulnerability Assessment

Another common part of risk management is *vulnerability assessment*. When you perform a vulnerability assessment, you identify, quantify, and prioritize the vulnerabilities in a system.

NOTE Vulnerability assessments can be performed for a wide variety of systems within an IT department and in a network as a whole.

Penetration Testing

Penetration testing can be an important part of the risk management processes for an organization. Penetration testing involves trying to find vulnerabilities and problems with the security settings of a network or network component. Penetration testing can help you find major problems with systems and mitigate the risk of cyberattack.

Posture Assessment

Another common part of risk management is *posture assessment*, which involves examining the state of a network and the network nodes from a security perspective. You can use the results of posture assessment to implement new security rules through a AAA system. With posture assessment, you can design requirements related to patch levels, software updates, or things like firewall rules. If an incoming system does not meet those requirements, you can deny it access to the network.

Business Risk Assessment

Thorough risk management processes might include business risk assessment. With this type of assessment, the focus may be on the business processes and vendors the

organization has partnered with. Process and vendor assessment are just two of the many types of business risk assessment an organization might perform.

Process Assessment

A thorough *process assessment* can help determine the security-consciousness of the various business processes that an organization engages in. Process assessments often concentrate on many other areas beyond security. For example, an organization may find many inefficiencies in the business processes in use daily.

One of the many reasons that business process assessments are necessary is that companies can get complacent and fail to update their process documentation even though many small changes have been implemented over time.

Vendor Assessment

A *vendor assessment* is a type of risk assessment in which a team analyzes the many vendors an organization uses in its business processes. This type of assessment considers how much organizational data vendors have access to, and the security practices of the vendors. There are a number of issues you should consider in assessing the vendors your business relies on.

Key Topic

Security Information and Event Management (SIEM)

Monitoring is a critical part of network security. For example, *security information and event management (SIEM)* software products and services combine security information management (SIM) and security event management (SEM).

SIEM systems provides real-time analysis of security alerts generated by applications and network hardware. These systems can log security data and generate reports for compliance purposes.

A SIEM system can take many forms; it can be implemented as software, as appliances, or as managed services.

Here are just some of the focuses of various SIEM products:

- **Log management:** This aspect of the SIEM helps administrators back up and archive the many log files in the network, along with many other management tasks appropriate for this data.
- **Security information management (SIM):** SIM focuses on long-term storage as well as analysis and reporting of log data.
- **Security event management (SEM):** SEM involves real-time monitoring, correlation of events, notifications, and console views.

- **Managed security service (MSS) or managed security service provider (MSSP):** The most common managed services are related to connectivity and bandwidth, network monitoring, security, virtualization, and disaster recovery.
- **Security as a service (SECaaS):** These security services often include authentication, antivirus, anti-malware/spyware, intrusion detection, penetration testing, and security event management, among others.

Physical Security

Have you ever had (the rather depressing) thought that all the hard work you have done in the operating system of a network device to secure it is worthless if an attacker gains physical access to your device? Someone who has physical access to a device might press a reset button in order to reset the device to factory defaults (allowing them to log in and reconfigure the device) or they might just take a less sophisticated approach and smash the device using a sledgehammer! If an attacker has access to your network equipment, you are in trouble. This section discusses physical security within the framework of two main principles, detection and prevention.

Detection Methods

When you think about detecting an attack against your network, you likely envision monitoring packets traveling into and out of your network devices. When you think about physical security, you can think in similar terms. You will certainly need to monitor the flow of humans into and out of the area where the network devices exist.

Today, there are many affordable options in the physical security detection realm of network security. Here are just some of the ones you should be aware of:

Key Topic

- **Motion detection:** Using either mechanical or electronic methods, you can install motion detection devices that alert you when objects change position in a physical network location.
- ***Cameras*:** Cameras enable you to view key network areas by using video surveillance. Video footage is often recorded and stored locally or in the cloud. Modern camera systems have been combined with more advanced intelligence to detect weapons and other threats.
- **Asset tracking tags:** You can use various wireless technologies to track the physical locations of network objects and personnel by using tag technologies attached to the entities. For example, radio frequency identification (RFID) uses electromagnetic fields and allows one-way communication of information from a chip to an RFID reader.

- **Tamper detection:** You can take steps to ensure that network equipment is not tampered with. For example, you might place key network cable runs in clearly viewable conduits and make appliances readily viewable through glass enclosures. You could also use IP camera systems to send alerts when certain areas containing hardware are infiltrated and tamper panels to detect when the cover of an all-in-one system or computer case is opened or tampered with.

Prevention Methods

There are many options you can use to assist in the area of physical attack prevention.

Many security professionals today will beg you to accept the fact that the most important prevention method you can take is complete and thorough *employee training*. One of the reasons for this common opinion is that many attacks cannot be carried out without user intervention. For example, social engineering requires a user to give sensitive information (such as username and password credentials) to an attacker in order for the attacker to access the user's account. As a result, a number of potential cybersecurity-related attacks can be thwarted through effective user training. For instance, users could be trained on using policies such as the following:

- Never give out your password to anyone, even if that person claims to be from IT.
- Do not open email attachments from unknown sources.
- Select strong passwords, consisting of at least 8 to 12 characters and containing a mixture of alphabetic (upper- and lowercase), numeric, and special characters.
- Do not visit unauthorized websites.
- Report suspicious activity.
- Do not run or install any applications not provided directly by the company.
- Change your passwords monthly.

This list is only an example, and you should develop a collection of best practices for your users based on your network's specific circumstances. Users should also know whom to contact in the event of a suspected data breach or compromise of the computers and systems the users are responsible for. Users should also know never to run penetration testing tools or other network discovery tools that may unintentionally lead to denial of service (DoS) or other harm to the network and its devices. Technical controls such as web/content filtering, port filtering, IP filtering, and access control lists (ACLs) that deny specific traffic can be used to assist in the enforcement of the policies agreed to by the users.

As part of user training and for the safety of human life, emergency procedures should also be communicated and verified with each user, including the

- Building layout
- Fire-escape plan
- Safety and emergency exits
- Doors that automatically fail closed or fail open based on their purpose to contain or allow access
- Emergency alert systems
- Fire suppression systems
- Heating, ventilation, and air conditioning (HVAC) operations
- Emergency shutoff procedures

In a data center, procedures for safety related to electrostatic discharge (ESD), grounding, rack installation, lifting, tool safety, and the correct placement of devices should also be planned, communicated, and verified. If there are dangerous substances in or near the work area, a material safety data sheet (MSDS) should be created to identify procedures for handling and working with those substances.

While employee training is undeniably important, keep in mind that it transcends just physical security concerns. Here are just some of the additional prevention methods you can engage in for physical security:

Key Topic

- **Badge readers:** Identification badges assist with physical security regarding employees. Badge readers are specialized hardware devices that read identification badges, and the data they collect is valuable for physical security. Whereas identification might be limited to name and photo, more sophisticated approaches can include electronic swipes and asset tags.
- **Biometrics:** Although at one time biometrics were reserved for the most sophisticated of environments, now using a thumbprint reader, facial recognition, or a retina scan is a reality with such common devices as cell phones.

NOTE It is common to refer to badge readers and biometrics as belonging to a category of devices called *access control hardware*.

- **Smart cards:** A smart card looks like a credit card but possesses circuitry that allows it to authenticate a user against network systems; this aids security and constitutes multifactor authentication (MFA) because the user must possess something (the smart card) and know something (the password). This MFA approach has worked well for ATMs in the banking system for decades.

- **Key fobs:** A key fob is an electronic attachment to a key ring that might provide access to a network system or might simply lock or unlock a secure door.
- ***Locks*:** Sometimes the simplest of security mechanisms are the most effective; this is often the case with locks on network areas and equipment. Your enterprise might feature racks for network equipment that have locking cages over them. These are often simply referred to as *locking racks*. You can also use *locking cabinets* for physical security.
- **Smart lockers:** It is always wonderful when one technology can assist another. This is certainly the case with smart lockers. These lockers might look like typical lockers from the outside, but they include network connectivity intelligence and might even be configured for Internet access. Smart lockers can accurately log user access and provide a level of security never before seen with basic lockers.
- **Access control vestibule:** There are at least two forms of social engineering attacks—tailgating and piggybacking—that require an attacker to follow an authorized user through a secured entrance or exit. An access control vestibule (formerly known as a mantrap), which is a small entry area with two interlocking doors, provides assurance that these forms of social engineering cannot take place.
- ***Geofencing*:** Geofencing is a technology that creates a virtual boundary around a real-world geographic area. When a person or device enters or exits this defined area, an action is triggered, such as sending a notification or starting an app. Businesses use geofencing for various purposes (not just security), like sending promotional messages to customers near their stores or tracking the location of employees in a specific work zone. It relies on GPS, Wi-Fi, or cellular data to determine the location and ensure the actions are taken based on the geographic boundaries.

Audits and Regulatory Compliance

Another important aspect of modern network security is conducting audits and ensuring compliance with regulations applicable to your organization. Here are just several important considerations in this area:

- ***Data locality*:** Where your data is located on the globe is really important when it comes to regulatory compliance. This is because different countries and regions have varying laws about where and how data can be stored and processed to protect privacy and security.

- ***Payment Card Industry Data Security Standards (PCI DSS)*:** PCI DSS is a set of security standards designed to ensure that all companies that accept, process, store, or transmit credit card information maintain a secure environment. It was created to protect cardholder data from theft and fraud. The standards include requirements for managing security, policies, procedures, network architecture, software design, and other critical protective measures. Compliance with PCI DSS helps businesses safeguard sensitive payment information and build customer trust.
- ***General Data Protection Regulation (GDPR)*:** GDPR is a set of rules created to protect the privacy and personal data of individuals in the European Union. It gives people more control over their personal information and requires organizations to be transparent about how they collect, store, and use this data. GDPR applies to any business, regardless of location in the world, that processes the data of EU citizens. It includes rights for individuals such as the right to access their data, the right to have it deleted, and the right to be informed about data breaches. The regulation aims to enhance privacy and trust in the digital age.

Real-World Case Study

Acme, Inc. is currently enhancing the security posture of the organization to safeguard against the evolving landscape of cyber threats. As part of this effort, Acme, Inc. is providing comprehensive training to the IT team, focusing on the most important network security concepts. The concepts include the most important principles of logical security and some of the most important physical security concepts.

In addition to bolstering the team's knowledge, the company is also deploying a well-regarded security information and event management (SIEM) system. This SIEM solution will play a crucial role in the day-to-day monitoring, detection, and management of potential security exploits. By centralizing and analyzing logs from various sources, the SIEM will enable the IT team to identify suspicious activities more swiftly and respond to threats in real time, thereby reducing the window of opportunity for malicious actors.

Furthermore, Acme, Inc. is making significant changes to its authentication methods to strengthen access controls across the enterprise network. The company is planning to implement multifactor authentication (MFA) for all users of its enterprise software. This move is intended to add an extra layer of security by requiring users to provide two or more verification factors to gain access, making it significantly harder for unauthorized individuals to breach the system.

Recognizing the importance of audits and regulatory compliance, Acme, Inc. is also providing recurring training on some of the most critical regulations that must be followed. This part of the training is also considering industry best practices in addition to those local and federal regulations that must be followed.

Ultimately, these efforts are part of a broader strategy by Acme, Inc. to create a robust and adaptive cybersecurity framework. By investing in both technology and training, the company is taking a holistic approach to security, ensuring that it is not only well prepared to handle current threats but also agile enough to respond to new challenges as they arise.

Summary

Here are the main topics covered in this chapter:

- This chapter reviewed key security concepts that you should be aware of in networking today. These include important concepts like CIA, symmetric and asymmetric encryption, and threats, vulnerabilities, and exploits.
- This chapter examined the various authentication methods that are popular today. These include technologies like MFA (multifactor authentication).
- This chapter also examined risk management and SIEMs. These can be important aspects of the security operations for the organization.
- Finally, this chapter also discussed physical security techniques as well as audits and regulatory compliance.

Exam Preparation Tasks

Review All the Key Topics

Review the most important topics from this chapter, noted with the Key Topic icon in the outer margin of the page. Table 18-1 lists these key topics and the page number where each is found.

Key Topic

Table 18-1 Key Topics for Chapter 18

Key Topic Element	Description	Page Number
Section	Confidentiality, Integrity, and Availability (CIA)	426
Section	Symmetric Encryption	427
Section	Asymmetric Encryption	428

Key Topic Element	Description	Page Number
Section	Integrity	430
Section	Least Privilege	433
Section	Security Information and Event Management (SIEM)	443
List	Detection methods	444
List	Prevention methods	446

Define Key Terms

Define the following key terms from this chapter and check your answers in the Glossary:

authentication; authorization; bring your own device (BYOD); camera; certificates; confidentiality, integrity, and availability (CIA); data at rest; data in transit; data in use; data locality; encryption; exploit; General Data Protection Regulation (GDPR); geofencing; guest network; honeynet; honeypot; identity and access management (IAM); industrial control system (ICS); Industrial Internet of Things (IIoT); Internet of Things (IoT); least privilege; Lightweight Directory Access Protocol (LDAP); locks; logical security; multifactor authentication (MFA); network segmentation enforcement; operational technology (OT); Payment Card Industry Data Security Standards (PCI DSS); physical security; public key infrastructure (PKI); Remote Authentication Dial-In User Service (RADIUS); risk; role-based access control (RBAC); Security Assertion Markup Language (SAML); self-signed; single sign-on (SSO); supervisory control and data acquisition (SCADA); Terminal Access Controller Access Control System Plus (TACACS+); threat; time-based authentication; vulnerability

Additional Resources

8 Most Common Cybersecurity Threats: https://www.youtube.com/watch?v=Dk-ZqQ-bfy4

10 Hacking Tactics You Should Know Of: https://www.youtube.com/watch?v=kOGSPHI-Ok4

Review Questions

The answers to these review questions appear in Appendix A, "Answers to Review Questions."

1. Which of the following is a symmetric encryption algorithm available in 128-bit, 192-bit, and 256-bit key versions?
   a. RSA
   b. 3DES
   c. AES
   d. TKIP

2. What aspect of modern cybersecurity focuses on ensuring that data has not been manipulated in transit?
   a. Integrity
   b. Confidentiality
   c. Authentication
   d. Availability

3. What security approach involves creating multiple accounts for your own access to the network and to its devices?
   a. 802.1X
   b. Least privilege
   c. Network access control
   d. SIEM

4. Which of the following is a device that is meant to attract security attacks?
   a. SIEM
   b. Geofencing
   c. IPS
   d. Honeypot

5. What network policy might permit company employees to use their own phones and tablets in the corporate data setting?
   a. Honeynet
   b. BYOD

c. IIoT
d. OT

6. Which of the following provides excellent search tools to leverage a large database of publicly known information security vulnerabilities and exposures?
   a. ACL
   b. AWS
   c. SHA-256
   d. CVE

7. Which of the following provides real-time analysis of security alerts generated by applications and network hardware and can log security data and generate reports for compliance purposes?
   a. SIEM system
   b. Screened subnet
   c. VRF instance
   d. Defense in depth

8. Which of the following is a client/server authentication protocol that supports mutual authentication between a client and a server and hands out tickets that are used instead of a username and password combination?
   a. TACACS+
   b. RADIUS
   c. Kerberos
   d. LDAP

9. You go to the store and put your bank card into an ATM and enter your PIN. Which of the following factors of multifactor authentication have you exhibited? (Choose two.)
   a. Something you are
   b. Something you have
   c. Something you know
   d. Somewhere you are

10. Which of the following would best help you ensure that all areas of control and compliance don't end up in the hands of a single individual?
    a. Role-based access control
    b. Zero trust
    c. Posture assessment
    d. Separation of duties

11. Which of the following is not a common physical security prevention method?
    a. Motion detection
    b. Employee training
    c. Locking racks
    d. Access control vestibule

12. Which of the following is not a common physical security detection method or tool?
    a. Camera
    b. Asset tag
    c. Tamper detection
    d. Biometrics

13. What does a public key infrastructure (PKI) system use for authentication and encryption services? (Choose two.)
    a. Digital certificates
    b. Certificate authority
    c. SHA-1
    d. SHA-2

14. Which is a computer threat that tries to exploit computer application vulnerabilities that are unknown to others—even the software developer?
    a. CVSS
    b. NAC
    c. Zero-day
    d. Least privilege

15. Which is a small entry area with two interlocking doors that provides assurance that tailgating and piggybacking forms of social engineering cannot take place?
    a. Geofencing
    b. Access control vestibule
    c. ESD
    d. MSDS

16. Which is a set of rules created to protect the privacy and personal data of individuals in the European Union (EU)?
    a. PCI DSS
    b. ICS
    c. OT
    d. GDPR

This page intentionally left blank